PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité et confiance de l'IA générative

03-960 ANSSI - Sécurité des systèmes d'IA générative et confiance dans l'IA par les risques cyber — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Le guide ANSSI-PA-102 formule 35 recommandations pour sécuriser les systèmes d'IA.
2. Les trois familles d'attaques spécifiques sont l'empoisonnement, l'extraction et l'évasion.
3. L'analyse de risque de février 2025 s'appuie sur les lignes directrices CISA et NCSC de novembre 2023.

Comparaison des documents ANSSI

Notion	À retenir
Guide technique 2024	Version **1.0** du **29 avril 2024** (**ANSSI-PA-102**). Formule **35 recommandations** (**R1** à **R35**) pour développeurs, administrateurs, RSSI, DSI et utilisateurs.
Analyse de risque 2025	Publiée en **février 2025**. Issue de travaux avec **CNIL**, **INRIA**, **LNE**, **PEReN** et **AMIAD**. S'appuie sur les lignes directrices **CISA** et **NCSC** de **novembre 2023**. Version anglaise cosignée (BSI, NCSC, CCCS, Singapour).

Synthèse des risques propres à l'IA

Notion	À retenir
Risques spécifiques	Vulnérabilités **logicielles** classiques + défis de **confidentialité/intégrité** des données + opacité (**boîtes noires**) compliquant l'investigation.
Familles d'attaques	**Empoisonnement** (données/modèle), **Extraction** (données confidentielles) et **Évasion** (altération des entrées pour détourner le comportement).
Scénarios de risque	Compromission **infrastructure/administration**, **chaîne d'approvisionnement** (calcul, modèles, données), **latéralisation** (interconnexions/injection indirecte), **lacunes humaines** (shadow IA) et **dysfonctionnements**.
Usage malveillant	Réduction de l'**expertise** requise et augmentation de l'**efficacité** (hameçonnage, ingénierie sociale, vulnérabilités, code malveillant). Attaques de **grande échelle** à moindre coût.

Cycle de vie et principes généraux

Notion	À retenir
Trois phases	Phases cycliques : **entraînement**, **déploiement** et **production**. Sécurité selon la sous-traitance, sensibilité des données et criticité.
Confiance composants	Évaluer **bibliothèques**, **modules** et **sources de données externes**. Appliquer **DevSecOps** et utiliser des **formats de modèles sécurisés**.
Confidentialité	Entraîner uniquement avec des **données légitimement accessibles** aux utilisateurs. **Proscrire** l'envoi de **données sensibles** vers les outils d'IA grand public sur Internet.

Recommandations clés du guide

Notion	À retenir
Maîtrise actions/accès	**R9** : proscrire l'usage automatisé pour actions critiques. **R10** : sécuriser accès à privilèges (admin/dev). **R27** : limiter actions automatiques via entrées non maîtrisées.
Hébergement/cloisonnement	**R11** : hébergement de confiance. **R12/R28** : cloisonnement phases/système. **R13** : passerelle Internet sécurisée. **R14** : privilégier **SecNumCloud**. **R15** : mode dégradé sans IA. **R16** : GPU dédiés. **R17** : canaux auxiliaires.
Intégrité et tests	**R19/R20** : intégrité données/fichiers. **R21** : proscrire ré-entraînement en production. **R22** : sécuriser déploiement. **R23/R24** : audits/tests métier. **R25** : filtrer entrées/sorties. **R26** : encadrer interactions. **R29** : journaliser traitements.
Cas particuliers	**R30/R31/R32** : contrôle/limitation/sensibilisation code généré. **R33** : durcir services grand public. **R34** : proscrire outils Internet pour données sensibles. **R35** : revue régulière des droits.

Recommandations de l'analyse de risque 2025

> Adapter complexité, maturité cyber, **auditabilité** et **explicabilité** à la sensibilité du cas d'usage ; ajuster l'**autonomie** et prévoir une **validation humaine** ; cartographier la **chaîne d'approvisionnement** et limiter les interconnexions ; superviser en continu, veille, former y compris les directions.

Pièges et confusions

- ⚠ Confondre l'empoisonnement, l'extraction et l'évasion qui sont les trois familles d'attaques spécifiques
- ⚠ Croire qu'un modèle peut être entraîné avec des données que ses utilisateurs n'ont pas le droit de connaître
- ⚠ Penser qu'une action critique sur le système peut être déclenchée automatiquement par une IA
- ⚠ Soumettre des données sensibles à des outils d'IA grand public
- ⚠ Ignorer que le shadow IA aggrave les fuites de données et la perte de maîtrise

Sigles et définitions

IA générative	sous-ensemble de l'intelligence artificielle axé sur des modèles entraînés à générer du contenu
LLM	catégorie de modèles d'IA générative capables de produire du texte proche du langage naturel
Modèle d'IA	réseau de neurones et ses paramètres, poids et biais
Système d'IA	englobe tous les composants techniques d'une application reposant sur un modèle d'IA
Prompt	instruction textuelle envoyée par l'utilisateur au système d'IA
Attaque adverse	consiste à envoyer au système des requêtes malveillantes pour le tromper ou altérer son fonctionnement
Shadow IA	utilisation de solutions d'IA générative grand public sans l'approbation ni la supervision des services informatiques
SecNumCloud	qualification de l'ANSSI pour les offres d'informatique en nuage de confiance

Auto-test

1. Combien de recommandations le guide ANSSI-PA-102 formule-t-il ?
2. Quelles sont les trois familles d'attaques spécifiques ?
3. Que signifie le terme shadow IA ?
4. Quelle qualification de l'ANSSI est mentionnée pour l'informatique en nuage de confiance ?
5. Quelles sont les trois phases du cycle de vie de l'IA ?

Réponses : **1.** 35 · **2.** L'empoisonnement, l'extraction et l'évasion · **3.** L'utilisation de solutions d'IA générative grand public sans l'approbation ni la supervision des services informatiques · **4.** SecNumCloud · **5.** Entraînement, déploiement et production

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.